MSM ACADEMY

SECTION 10

Lead Implementer simulation



10.1 Engagement, context and scope
10.2 Gap analysis and plan
10.3 Risk, treatment and SoA
10.4 Documents, controls and go-live
10.5 Check and ready

SECTION 10

Quenvale at Month 0

A capable company without a management system

- Global B2B payroll and HR software as a service; about 420 staff and 60 contractors
- Headquarters in Europe, engineering centre in Asia-Pacific, support centre in North America; about 20% remote
- Strong engineering security; policies, risk, suppliers and access reviews fragmented

MSM ACADEMY

SECTION 10 · LESSON 10.1

Engagement, context and scope

10.1

Initiate · Understand — Months 0 to 1

LESSON 10.1 · EVIDENCE

The certification trigger

Why Quenvale called you

- Two enterprise prospects require ISO/IEC 27001 certification within 12 months of contract signature
- The largest customers negotiate audit rights and breach notification within 48 hours
- Last year: a misconfigured cloud storage bucket held a test copy of real customer data

LESSON 10.1 · CONVERSATION

“Put the whole company in”



Adaeze Okonkwo CEO, Quenvale

“Twelve months is tight, so let’s keep it simple. Put everything in scope, the analytics start-up we bought too. Customers should see one certificate.”

YOU

Your move: Decide how the ISMS will be governed, and keep her scope request in mind.

Your move: charter and governance

Quenvale today:

- The CEO sponsors the work; the CTO and CFO sponsor security spending
- Rafael Moreira is Head of Information Security
- No ISMS roles, steering group or decision rights exist
- You are external and leave at Month 8

Who chairs, who runs the ISMS day to day, and what does the steering group decide?



Pause the video

Then compare with the model answer.

Model answer: charter and governance

Chair and sponsor	Adaeze Okonkwo, CEO
ISMS Manager	Rafael Moreira, Head of Information Security
Steering group	CEO, COO, information security, engineering, HR, IT operations; monthly
Decision rights	Scope, risk criteria, plan and resources; CEO approves the ISMS policy

Build the ISMS around what works; you support, Quenvale owns.

LESSON 10.1 · EVIDENCE

Context and climate facts

What the context review found

- Engineering centre: seasonal flooding; last year a two-day regional power and internet outage
- Headquarters: longer heatwaves; comms-room cooling sized years ago; a high-temperature alarm last summer
- Production: each customer’s data stays in one cloud region; enterprise prospects ask about extreme-weather resilience

Your move: is climate change relevant?

The facts:

- Flooding outage at the engineering centre
- Heat stress on the HQ comms room
- Single-region data residency and a 99.9% availability commitment
- Customers asking about extreme-weather resilience

Determine whether climate change is a relevant issue for the ISMS, and justify it.



Pause the video

Then compare with the model answer.

Model answer: climate determination

Determination	Relevant
Why	Availability and continuity at sites and in cloud regions; customers’ resilience requirements
Where it goes	Risk assessment (heat, regional outage), continuity, physical and utility controls
What it is not	A separate climate programme



A determination is backed by facts and feeds the risk assessment.

LESSON 10.1 · EVIDENCE

The acquisition

The boundary question

- Acquired six months ago: a workforce-analytics start-up, about 30 staff
- Its own systems and office; integration planned for next year
- One connection: an API that receives anonymised, aggregated data from the platform

LESSON 10.1 · YOUR MOVE

Your move: the scope boundary

Options:

- Include the start-up now, as Adaeze asks
- Exclude it completely
- Exclude it, but keep its interface in scope

Clause 4.3 asks you to consider interfaces and dependencies.

Decide the boundary, and how you will justify it to Adaeze.



Pause the video

Then compare with the model answer.

Model answer: the scope statement

“The information security management system of Quenvale covers the design, development, operation and support of the Quenvale payroll and HR software-as-a-service platform, including the people, processes, technology and facilities that support it at the Headquarters, the Engineering centre and the Customer support centre, the platform’s production environment hosted in public cloud regions in Europe and North America, and remote working.”

Boundary decision

- The start-up is excluded until integration: separate staff, systems and office
- Its API interface, and the controls on it, are inside the scope
- To Adaeze: one certificate customers can trust; the start-up joins at integration

MSM ACADEMY

SECTION 10 · LESSON 10.2

Gap analysis and plan

Understand — Months 1 to 2

10.2

LESSON 10.2 · CONVERSATION

“Engineering already does risk assessment”



Rafael Moreira Head of Information Security

“Every product has a threat model, reviewed at each release. That’s risk assessment. Can we rate 6.1.2 as Comply and move on?”

YOU

Your move: Rate the gap analysis rows on the next slide, starting with his.

Gap analysis: evidence gathered

Requirement	What you found
6.1.2 Risk assessment process	Product threat models in engineering; no company-level method, criteria or register
A.5.18 Access rights	Reviews happen only when someone remembers
A.5.22 Supplier monitoring	Questionnaire at onboarding; no reassessment since
A.8.13 Backup	Daily cloud backups; restores tested ad hoc; no recovery objectives
A.8.25, A.8.28 Secure development	Code review, pipeline scanning, annual penetration test

Your move: rate the rows

Ratings available:

- Comply: implemented and working
- Partially implemented: some practice, incomplete
- Not implemented: no evidence

And Rafael’s question: are threat models the 6.1.2 process?

Rate each row, name the evidence that decides it, and answer Rafael.



Pause the video

Then compare with the model answer.

Model answer: ratings

Requirement	Rating	Deciding evidence
6.1.2 Risk assessment	Not implemented	No company method, criteria, register or owners
A.5.18 Access rights	Partially	Practice exists, not scheduled or evidenced
A.5.22 Supplier monitoring	Not implemented	No reassessment after onboarding
A.8.13 Backup	Partially	Backups run; restores and objectives missing
A.8.25, A.8.28 Development	Comply	Working practice with evidence

Your move: sequence the plan

You have:

- Eight months until handover
- Strong engineering practice to build on
- No risk method, policy set, internal audit or management review
- A certification deadline driven by customer contracts

Put the work in order for an eight-month engagement.



Pause the video

Then compare with the model answer.

Model answer: the implementation plan

Months	Work	MSM phase
0–1	Charter, context, interested parties, scope	Initiate, Understand
1–2	Gap analysis and plan	Understand
2–4	Risk method, assessment, treatment, SoA	Design
3–6	Documents and controls; go-live at Month 6	Implement
7–8	Internal audit, management review, handover	Check, Ready

MSM ACADEMY

SECTION 10 · LESSON 10.3

Risk, treatment and SoA

Design — Months 2 to 4



Quenvale’s risk criteria

Score	Level	Who may accept
1–3	Low	Risk owner
4–6	Medium	Risk owner, reporting to the ISMS committee
8–12	High	Treat; temporary retention only with top-management approval and a dated plan
15–25	Very high	Priority treatment; exceptional top-management override
Consequence 5	Any score	Top-management decision

Risk register: sample

Risk	C × L	Level	Owner
R-01 Legacy HQ file server exposes poorly classified data	4 × 3 = 12	High	COO
R-02 Heatwave overheats the HQ comms room	3 × 3 = 9	High	IT Operations
R-03 Personal data exposed through the anonymised feed	2 × 1 = 2	Low	Engineering
R-05 Support-centre leavers keep ticketing access	3 × 4 = 12	High	IT Operations
R-06 Regional cloud outage from severe weather	4 × 2 = 8	High	Engineering

LESSON 10.3 · CONVERSATION

“Retiring the server is excessive”



Ivan Petrović IT Operations Manager

“That server has run for years without a problem. Retiring it by Month 12 is excessive. Keep it two more years with antivirus. I run it, so I’ll sign off the risk.”

YOU

Your move: Judge his proposal: the treatment, and who may accept the risk.

LESSON 10.3 · YOUR MOVE

Your move: treatment and acceptance

R-01 legacy file server:

- Current risk 12, High; risk owner the COO
- Criteria: High must be treated; temporary retention only with top-management approval and a dated plan
- Ivan’s proposal: keep it two years with antivirus; he accepts

Is Ivan’s treatment adequate, and can he accept this risk?



Pause the video

Then compare with the model answer.

LESSON 10.3 · MODEL ANSWER

Model answer: the legacy file server

Treatment	Retire by Month 12; interim controls now: restricted access, MFA, monitoring
Interim residual	8, High: retained temporarily with a dated plan
Who accepts	The COO, as top management and risk owner, not Ivan
Ivan’s role	Implements the controls; his migration concerns shape the plan



The criteria, not the person closest to the system, decide who may accept.

Statement of Applicability: extract

Control	Necessary	Justification
5.14 Information transfer	Yes	R-03; critical suppliers
6.7 Remote working	Yes	R-07; operational need (20% remote)
7.11 Supporting utilities	Yes	R-02
8.32 Change management	Yes	R-03

Your move: three SoA rows

Decide necessity and justification for:

- 5.23 Information security for use of cloud services
- 8.30 Outsourced development
- 8.33 Test information

Facts: production runs in public cloud; about 25 contract developers work inside Quenvale’s own engineering process; the Month-0 near-miss involved test data.

Necessary or not, and why?



Pause the video

Then compare with the model answer.

Model answer: three SoA rows

5.23 Cloud services	Necessary: R-06 and critical cloud suppliers
8.30 Outsourced development	Not necessary: no development is outsourced; contractors work inside Quenvale’s own process
8.33 Test information	Necessary: operational need shown by the Month-0 near-miss



Exclusions are allowed when justified; Annex A is a completeness check, not a checklist.

MSM ACADEMY

SECTION 10 · LESSON 10.4

Documents, controls and go-live

10.4

Implement — Months 3 to 6

Tailoring the Option 1 toolkit

Quenvale uses Toolkit Option 1

- Short Level 1 policies, with guidelines and procedures underneath
- Personal phones are allowed for email and chat
- Engineering practice already works and must not be rewritten

LESSON 10.4 · YOUR MOVE

Your move: tailor the documents

For each, keep, merge or remove, and what must it say?

- BYOD policy
- Mobile device and teleworking policy
- Secure development documents
- Change management procedure
- Incident management procedure
- ISMS policy

Decide what to keep, and what each document must say for Quenvale.



Pause the video

Then compare with the model answer.

LESSON 10.4 · MODEL ANSWER

Model answer: tailoring

BYOD policy	Keep: email and chat only through managed app protection; no customer-data downloads
Mobile and teleworking	Keep: about 500 managed laptops; hybrid working
Secure development	Keep, describing existing engineering practice
Change and incident	Keep, tailored; the steps come next

Tailor to how Quenvale works; keep only what Quenvale will use.

LESSON 10.4 · CONVERSATION

“Code review already covers it”



Sunita Rao Head of Engineering

“Every change to the analytics feed already goes through code review. The data leaves anonymised and aggregated. A separate security review just slows us down.”

YOU

Your move: Decide whether code review is enough, and what triggers a security review.

Your move: the interface security review

Facts:

- The feed is anonymised and aggregated before it leaves
- The start-up is outside the scope; the interface is inside
- Code review checks whether the code is correct
- Risk R-03 is Low because the data is anonymised

Is code review enough? If not, what exactly triggers a security review?



Pause the video

Then compare with the model answer.

Model answer: interface security review

Decision	Add a mandatory security review step to the change procedure
Trigger	Any change to the anonymised data interface: schema, attributes, aggregation or access
Owner	Sunita Rao reviews and records it before release
Effective	Month 5

Code review checks the code; the security review checks what the data could reveal.

Controls set up for go-live

Control	Quenvale arrangement
Access reviews	Quarterly from Month 7; Operations Team Lead
Supplier monitoring	Tiers; tier 1 reassessed yearly; first cycle Months 9–12
Backup	Full restore test twice a year against RTO 8 h and RPO 24 h; first at Month 11
Incidents	Detection provider alerts the ISMS Manager; notification decision within 24 hours

Your move: go-live at Month 6

It is Month 6. Adaeze asks:

“Are we live? What has to exist before we call it running?”

Decide what must exist before Quenvale goes live.



Pause the video

Then compare with the model answer.

Model answer: go-live

Policies	Approved by top management and issued
People	Awareness launched
Measures	Objectives set; monitoring started
Records	Operating records start from here

Go-live is when the system starts producing evidence of its own operation.

MSM ACADEMY

SECTION 10 · LESSON 10.5

Check and ready

Check · Ready — Months 7 to 8

10.5

The first internal audit

Item	Result
Auditor	External internal auditor engaged by Quenvale, independent of the implementation
Scope	Clauses 4 to 10 and a sample of Annex A controls
Nonconformity	7.3 Awareness: contractors doing work have not received it
Opportunities	Evidence retrieval could be faster; metric trends could be easier to read

LESSON 10.5 · CONVERSATION

“Contractors are the agency’s problem”



Claire Dubois HR Director

“The contract developers belong to the agency. Their employer trains them. Why is our awareness programme suddenly responsible for them?”

YOU

Your move: Decide whether awareness applies to contractors, and what corrective action fixes the cause.

Your move: the corrective action

Facts:

- About 25 contract developers work in Quenvale’s engineering centre
- The agency runs their onboarding
- Quenvale’s onboarding checklist does not include the awareness programme

Does 7.3 apply to them? What correction, and what corrective action addresses the cause?



Pause the video

Then compare with the model answer.

Model answer: the corrective action

Requirement	Yes: 7.3 covers persons doing work under Quenvale’s control
Correction	Enrol all current contractors now
Root cause	Agency-run onboarding; Quenvale’s checklist omitted awareness
Corrective action	Add awareness to Quenvale’s contractor onboarding checklist, before access; due Month 10; owner Claire



A correction fixes this case; a corrective action fixes the cause.

LESSON 10.5 · CONVERSATION

“Can we bring Stage 1 forward?”



Adaeze Okonkwo CEO

“The enterprise customers signed at Month 5 and they’re nervous. Can we bring Stage 1 forward to Month 10 and show them progress?”

YOU

Your move: Decide what the management review must cover, and when Stage 1 should be.

Your move: management review and Stage 1

Facts:

- Go-live was Month 6; one internal audit is done
- Four items are deliberately open, with owners and dates
- Certification is required by Month 17
- Stage 1 checks readiness, including operating evidence

What must the review cover, and when should Stage 1 take place?



Pause the video

Then compare with the model answer.

Model answer: management review and Stage 1

Review inputs	The required inputs, with the evidence assembled in MR-01
Conclusion	Implementation established; ready to enter the operating period
Stage 1	Month 15, after months of operating records; certification still by Month 17
Plan	Certification-readiness plan approved; certification body selected



Readiness is earned by operating evidence, not by the calendar.

The handover list

Open item	Owner	Due
Legacy file server retirement	COO	Month 12
First full supplier reassessment cycle	Rafael Moreira	Months 9–12
First full restore test	Ivan Petrović	Month 11
Contractor awareness corrective action	Claire Dubois	Month 10

LESSON 10.5 · MODEL ANSWER

What you leave behind

Owners	People who run their own processes
Schedule	Quarterly reviews, restore tests, supplier cycles, next internal audit
Plan	An approved certification-readiness plan; Stage 1 at Month 15
Dependency	None on the consultant



A good implementation ends when the organization no longer needs you.

SECTION 10 · KNOWLEDGE CHECK

Check your understanding

At handover, which best shows that Quenvale’s ISMS does not depend on the consultant?

A. Every open item is closed before the consultant leaves

B. Owners run their processes, and open items are owned and dated

C. The consultant is retained to run the internal audits

D. A certification date has been confirmed with the certification body

Check your understanding

At handover, which best shows that Quenvale’s ISMS does not depend on the consultant?

A. Every open item is closed before the consultant leaves

B. Owners run their processes, and open items are owned and dated

C. The consultant is retained to run the internal audits

D. A certification date has been confirmed with the certification body

Answer: B

Independence comes from owners running their processes, with any open items owned and dated. Closing everything is not required; a consultant running audits creates dependency; a date is not readiness.

SECTION 10 COMPLETE

Nine months later

Next: Section 11 · independent certification-body Lead Auditor

